Esercizio Teorico: Null Session e ARP Poisoning

1. Che cosa si intende per Null Session

Una Null Session è una connessione a servizi SMB/NetBIOS di un sistema Windows che viene effettuata senza fornire credenziali di autenticazione.

In passato alcuni sistemi Windows consentivano agli utenti anonimi di accedere a informazioni di rete, come:

- Elenco degli utenti presenti nel sistema
- Elenco dei gruppi
- Condivisioni di rete
- Informazioni sul dominio

Un attaccante poteva sfruttare queste informazioni per raccogliere dati utili ad attacchi successivi, come brute force o privilege escalation.

2. Sistemi vulnerabili a Null Session

Le Null Session interessavano principalmente:

- Windows NT 4.0
- Windows 2000
- Windows XP
- Windows Server 2003

Questi sistemi sono oggi considerati obsoleti e non sono più supportati da Microsoft.

3. Modalità per mitigare o risolvere la vulnerabilità Null Session

Le principali contromisure sono:

- Disabilitare le connessioni anonime.
- Limitare l'accesso alle condivisioni SMB.
- Applicare gli aggiornamenti di sicurezza del sistema operativo.
- Disabilitare NetBIOS se non necessario.

- Utilizzare firewall per limitare l'accesso alle porte SMB (137, 138, 139 e 445).
- Applicare il principio del minimo privilegio.
- Monitorare i log di sicurezza per individuare connessioni sospette.

ARP Poisoning

4. Come funziona l'ARP Poisoning

L'ARP Poisoning (o ARP Spoofing) è una tecnica che sfrutta il protocollo ARP (Address Resolution Protocol). Il protocollo ARP viene utilizzato per associare un indirizzo IP a un indirizzo MAC all'interno della stessa rete locale.

L'attaccante invia pacchetti ARP falsificati ai dispositivi della rete facendo credere:

- al computer vittima che il MAC dell'attaccante corrisponda al gateway;
- al gateway che il MAC dell'attaccante corrisponda alla vittima.

In questo modo il traffico passa attraverso il sistema dell'attaccante che può:

- intercettare il traffico;
- modificarlo;
- registrarlo;
- effettuare attacchi Man-In-The-Middle (MITM).

5. Sistemi vulnerabili ad ARP Poisoning

Sono vulnerabili praticamente tutti i dispositivi che utilizzano ARP nelle reti IPv4:

- Windows
- Linux
- macOS
- Router
- Stampanti di rete
- Telecamere IP
- Switch non gestiti
- Dispositivi IoT

La vulnerabilità deriva dal protocollo ARP stesso, che non prevede meccanismi di autenticazione.

6. Modalità per mitigare, rilevare o annullare l'ARP Poisoning

Mitigazione

- Utilizzare switch gestiti con Dynamic ARP Inspection (DAI).
- Utilizzare il protocollo HTTPS.
- Utilizzare VPN.
- Configurare tabelle ARP statiche nei sistemi critici.
- Segmentare la rete mediante VLAN.

Rilevamento

- Monitorare le variazioni delle tabelle ARP.
- Utilizzare strumenti come:
    - arpwatch
    - XArp
    - Wireshark

Annullamento

- Svuotare la cache ARP.
- Riavviare le interfacce di rete.
- Rimuovere il dispositivo malevolo dalla rete.
- Ripristinare le corrette associazioni IP-MAC.

Esercizio Pratico: Ettercap e ARP Poisoning

Obiettivo

L'obiettivo dell'esercitazione era simulare un attacco di tipo ARP Poisoning utilizzando il software **Ettercap** all'interno di una rete locale.

Procedura eseguita

È stato avviato Ettercap e selezionata l'interfaccia di rete **eth0**.

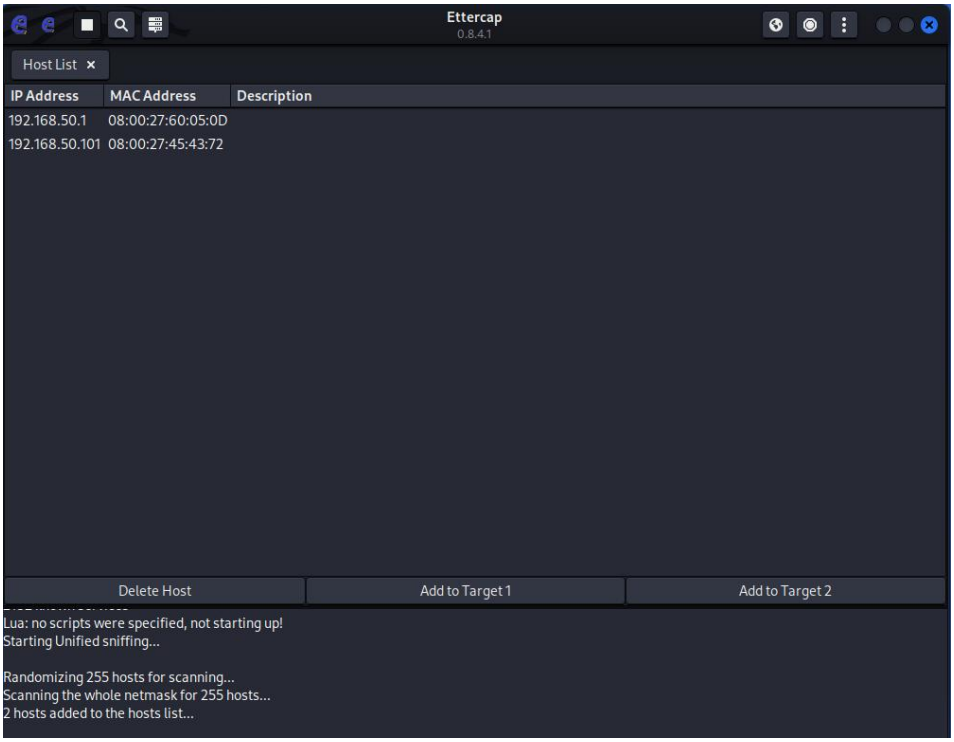
Successivamente è stata effettuata una scansione della rete locale e sono stati individuati due host:

- 192.168.50.1
- 192.168.50.101



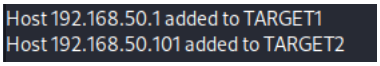
I due indirizzi IP sono stati selezionati rispettivamente come:

- Target 1 → 192.168.50.1
- Target 2 → 192.168.50.101



Problema riscontrato

Dopo aver selezionato correttamente i target, si è tentato di avviare la funzione:



Mitm → ARP Poisoning

Tuttavia il programma non ha completato l'operazione.

Durante i test effettuati il software Ettercap versione 0.8.4.1 si chiude inaspettatamente quando viene selezionata l'opzione ARP Poisoning, impedendo l'avvio dell'attacco.

Di conseguenza non è stato possibile completare la fase pratica di intercettazione del traffico.

Conclusioni

La parte teorica dell'esercitazione ha permesso di comprendere il funzionamento delle Null Session e dell'ARP Poisoning, le relative vulnerabilità e le tecniche di mitigazione.

Per quanto riguarda la prova pratica con Ettercap, è stato possibile configurare correttamente l'interfaccia, eseguire la scansione della rete e selezionare i target. Tuttavia l'attacco non è stato completato poiché il software si arresta in modo anomalo quando viene avviata la funzione ARP Poisoning, probabilmente a causa di problemi di compatibilità della versione utilizzata.